



■ Pruebas de penetración

- 2.4.1 Explotación de redes

Contenidos

- Seguridad en redes.
- Ataques comunes.
- Herramientas de sniffing.
- Técnicas de detección.
- Protocolos seguros.

A black and white photograph of a man in a suit standing in a modern office, holding a tablet and smiling. The office has glass partitions and modern lighting. A blue square is in the top right corner.

01

Seguridad de redes

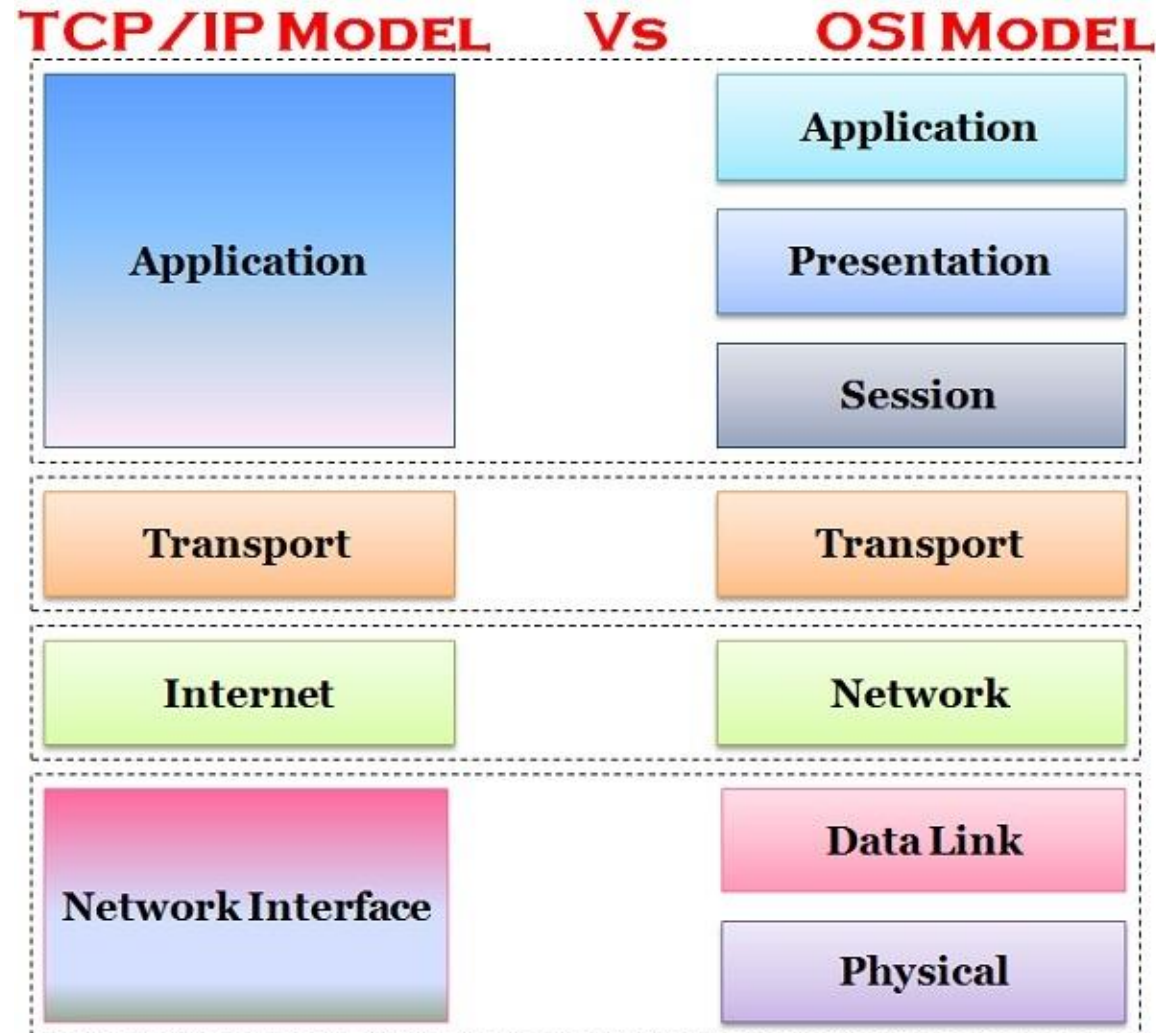
Introducción

Uno de los factores más importantes de la ciberseguridad radica en el uso de protocolos inseguros, sobre todo en las redes internas.

El tráfico de red muchas veces circula sin ningún tipo de protección, lo que permite a los atacantes hacerse de información sensible o confidencial.

Las técnicas utilizadas por los atacantes, como se verá en este módulo, basan su efectividad, principalmente, en las debilidades que tienen los protocolos de red, muchos de los cuales datan de hace más de 40 años.

Modelo OSI-TCP/IP

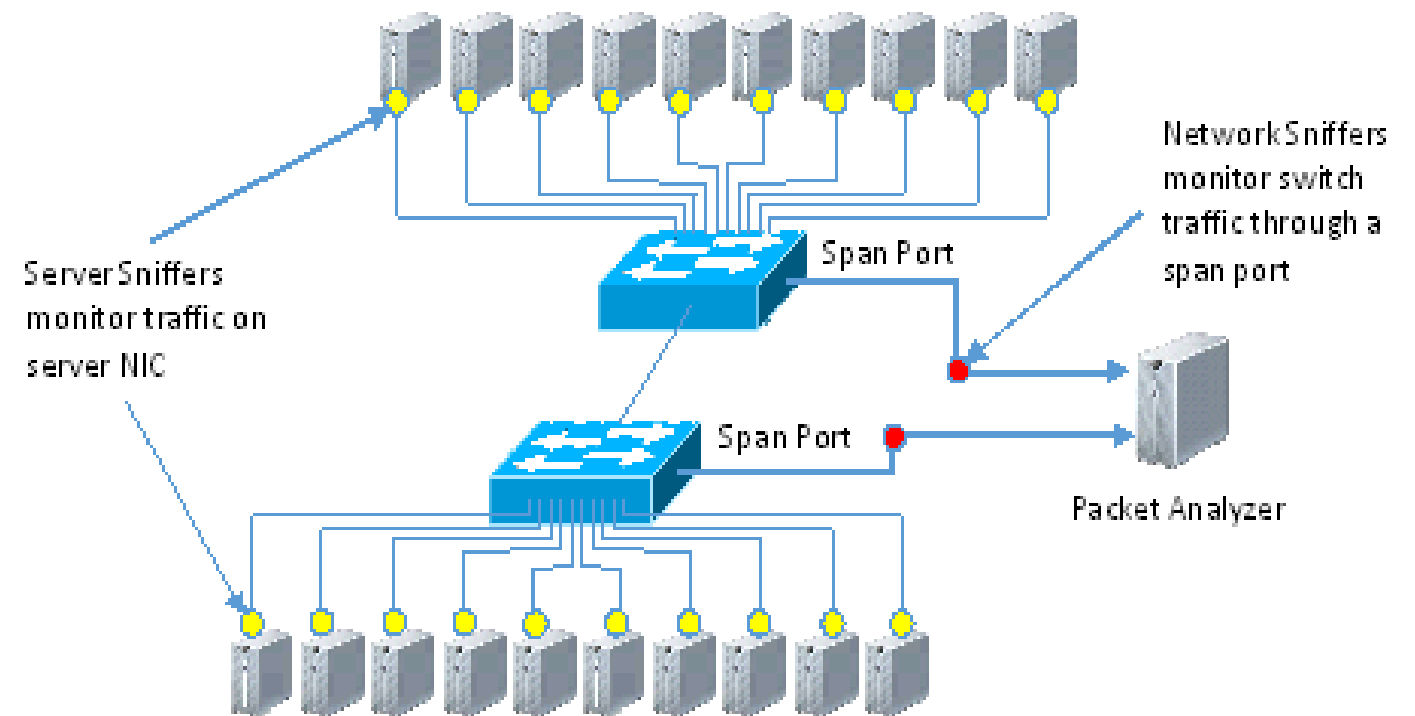


Sniffing

Es el proceso de monitorear y capturar todos los paquetes de datos que pasan a través de una red informática, mediante rastreadores de paquetes. Los administradores de red utilizan Packet Sniffers para realizar un seguimiento del tráfico de datos que pasa a través de su red. Estos se denominan analizadores de protocolos de red.

De la misma manera, los atacantes malintencionados emplean el uso de estas herramientas de rastreo de paquetes para capturar paquetes de datos en una red.

Arquitectura de un sniffer en red

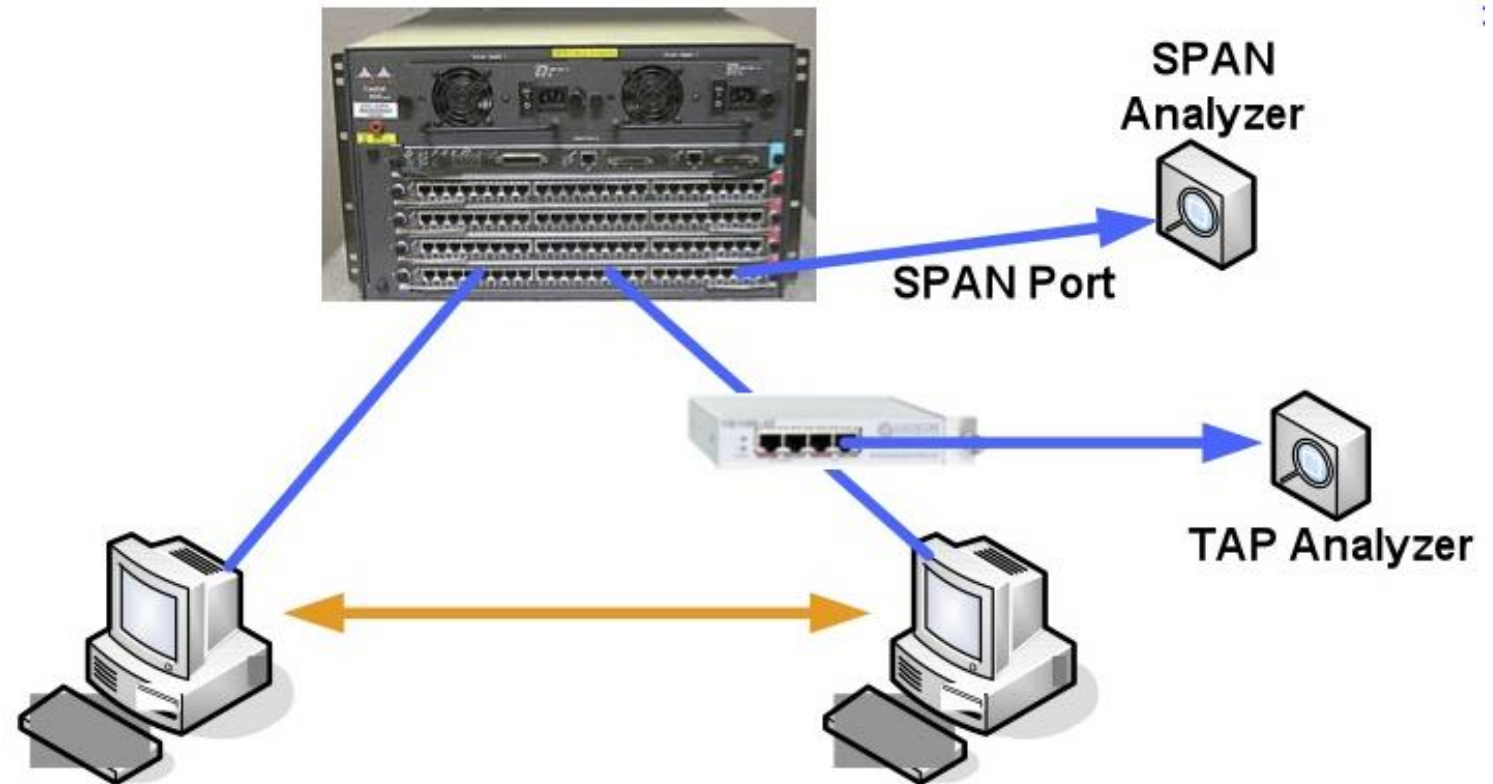


Tipos de sniffing:

Pasivo: Solo se dedica a la captura de tráfico, sin intervenir en este, sin alterarlo o modificarlo. Es uno de los ataques más silenciosos, dado que no genera ningún tipo anomalía que pueda ser detectada.

Activo: Además de robar tráfico de red, puede alterarlo, incluso en forma maliciosa para denegar el servicio de red de los usuarios o robar datos confidenciales.

Conexiones de sniffers



Protocolos vulnerables

- Telnet.
- Rlogin.
- HTTP.
- IMAP.
- POP.
- SMTP.
- FTP.
- SIP (Telefonía IP).



A black and white photograph of a man and a woman in a modern office setting. The man, on the left, is wearing a light-colored button-down shirt and dark trousers. The woman, on the right, is wearing a dark blazer over a light-colored turtleneck. They are both looking at a tablet held by the man. In the background, there are office desks, computer monitors, and a person sitting at a desk. The overall atmosphere is professional and collaborative.

02

Ataques basados en sniffing

• Introducción

• Ataques basados en sniffing:

- MAC Flooding.
- DNS Poisoning.
- ARP Spoofing.
- DHCP Spoofing.
- Switch and port stealing.
- Spoofing.



MAC Flooding

MAC	PORT
A	1
C	3

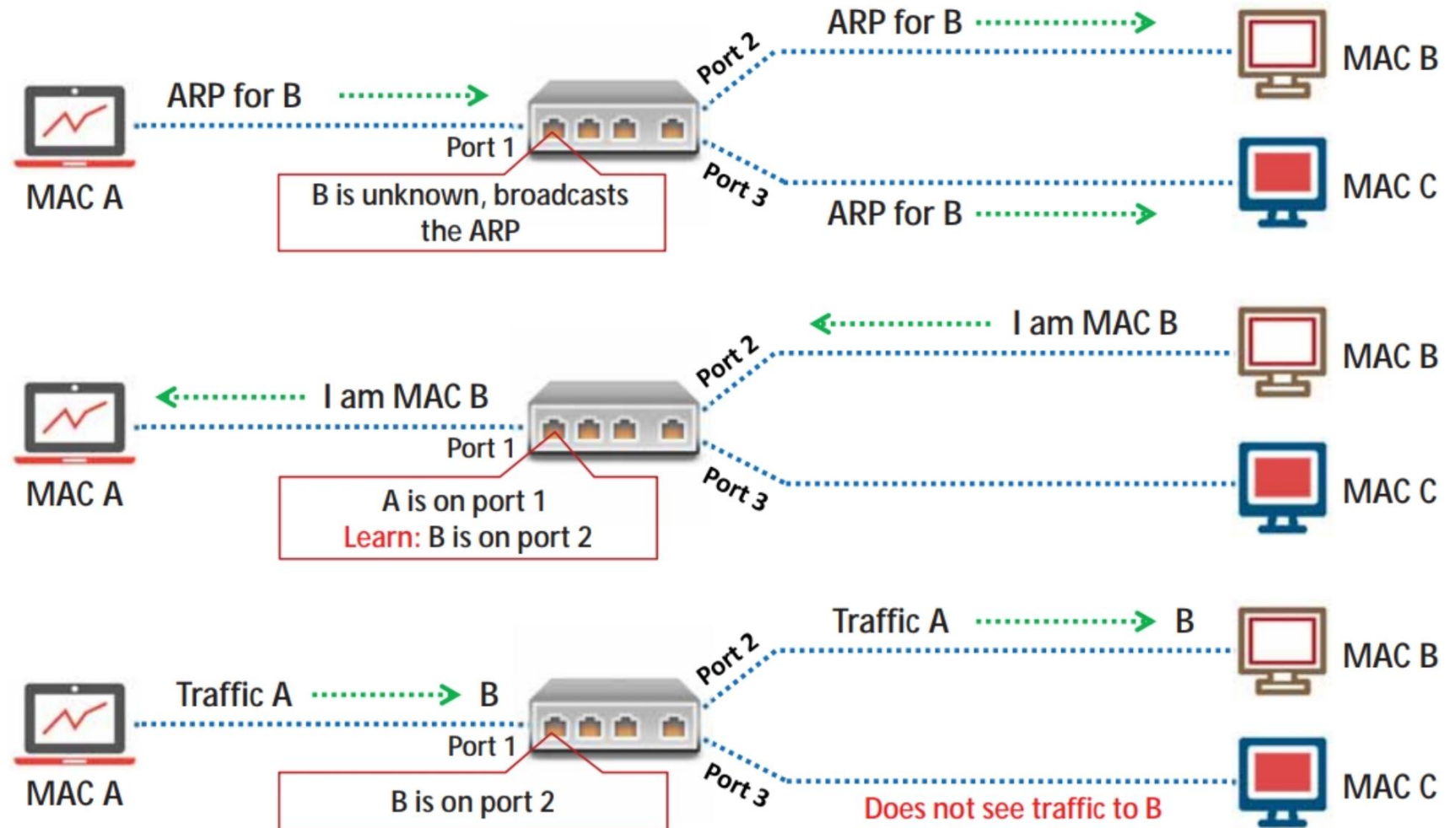
CAM Table

MAC	PORT
A	1
B	2
C	3

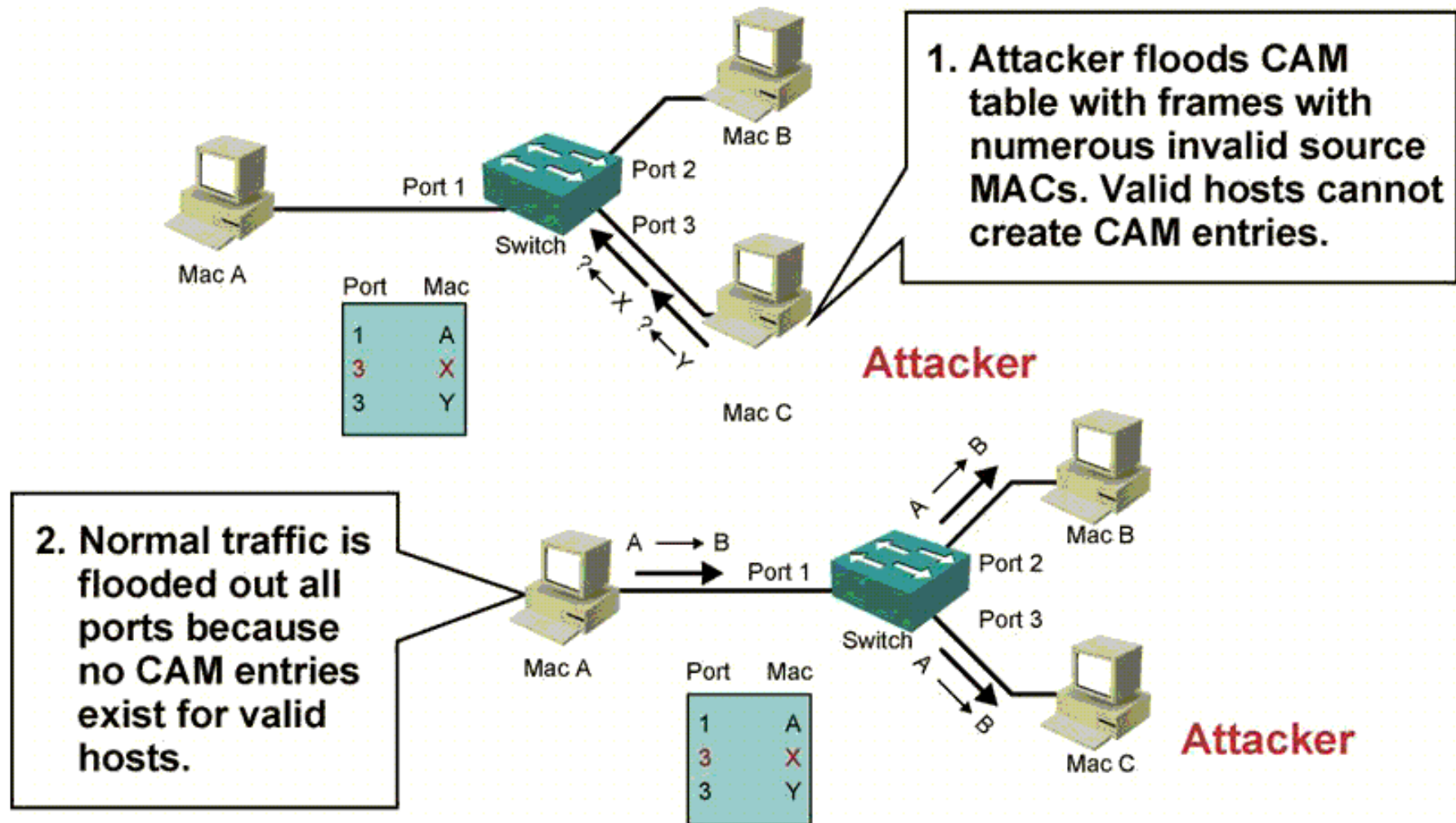
CAM Table

MAC	PORT
A	1
B	2
C	3

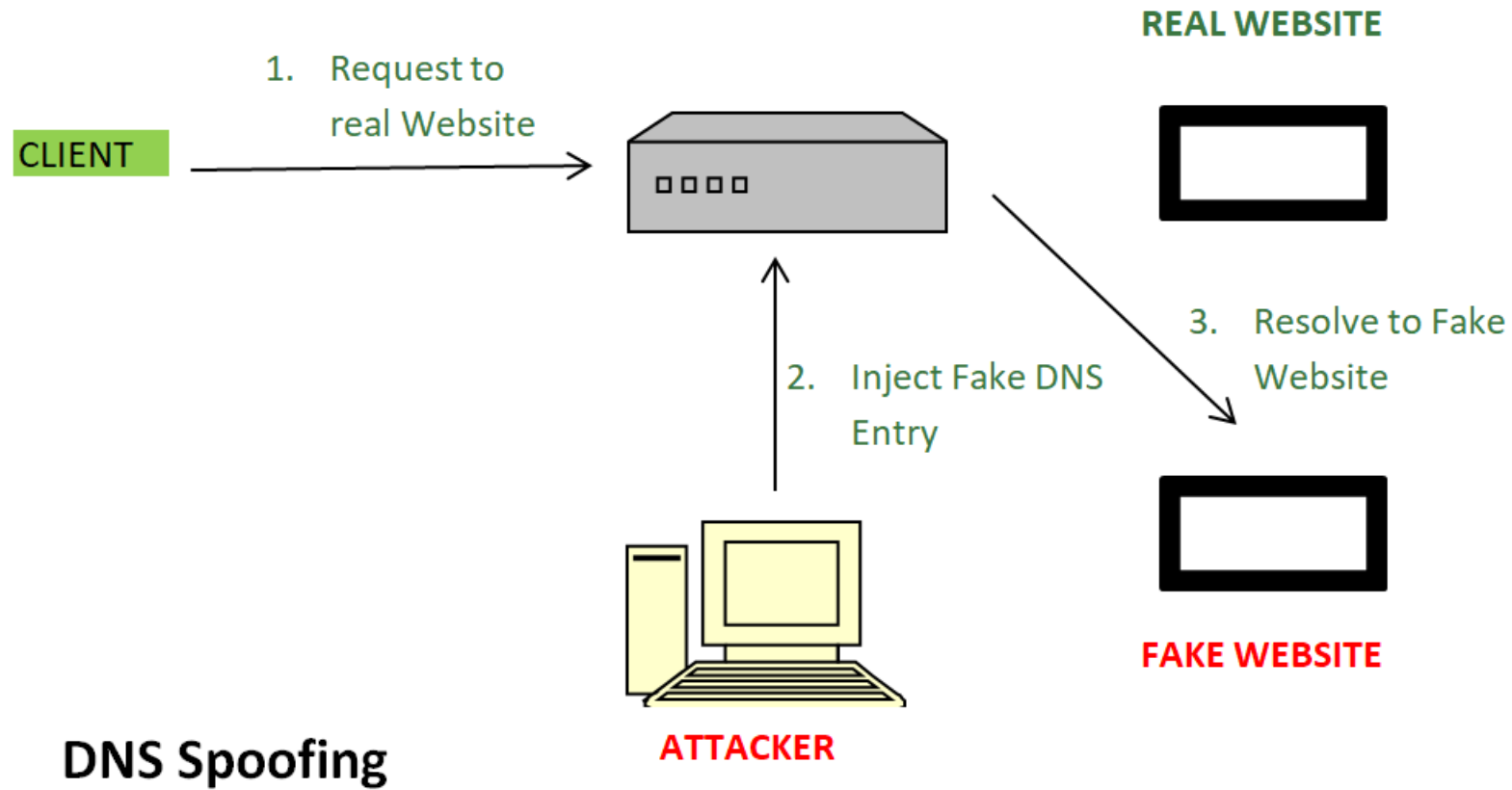
CAM Table



MAC Flooding

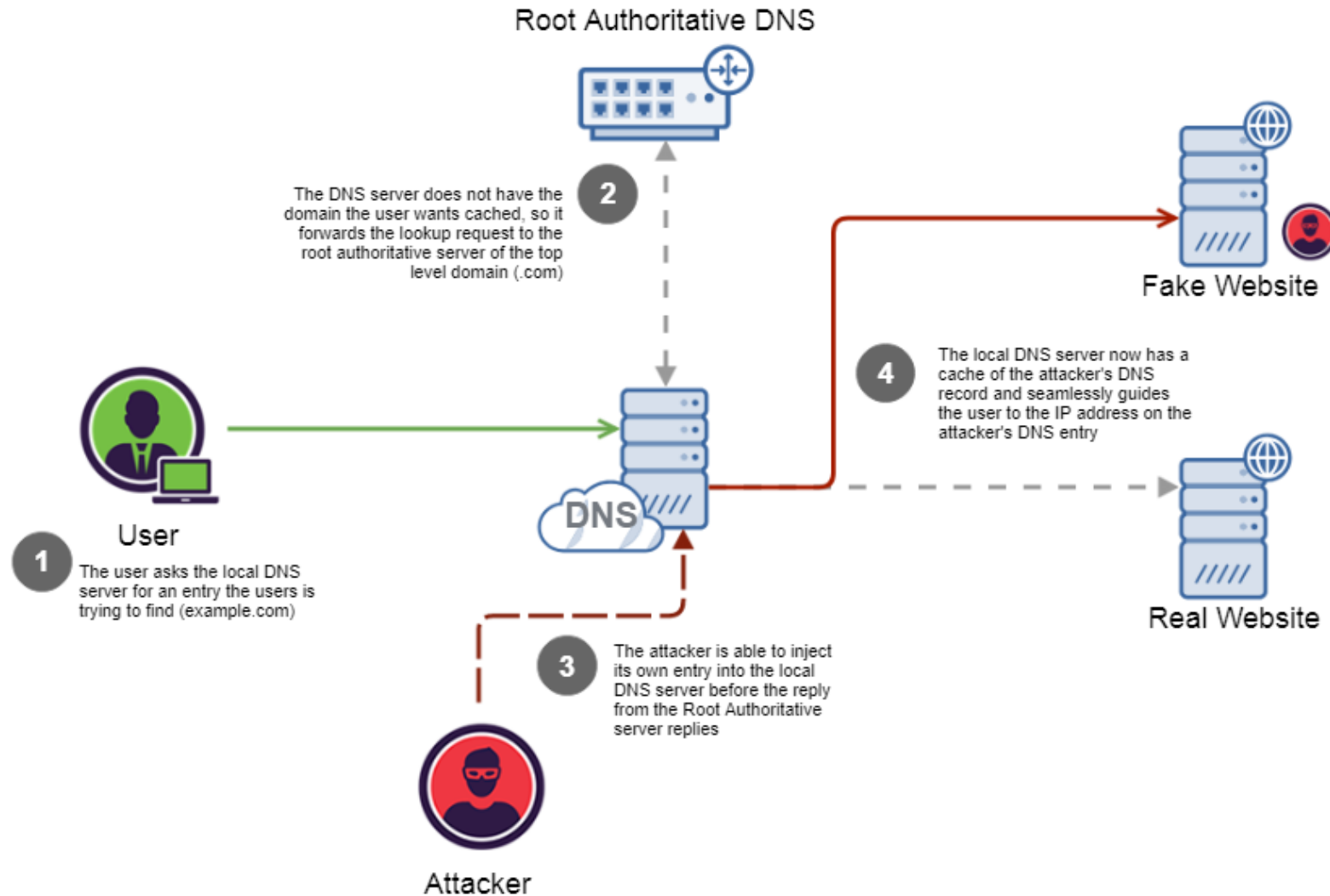


DNS Spoofing

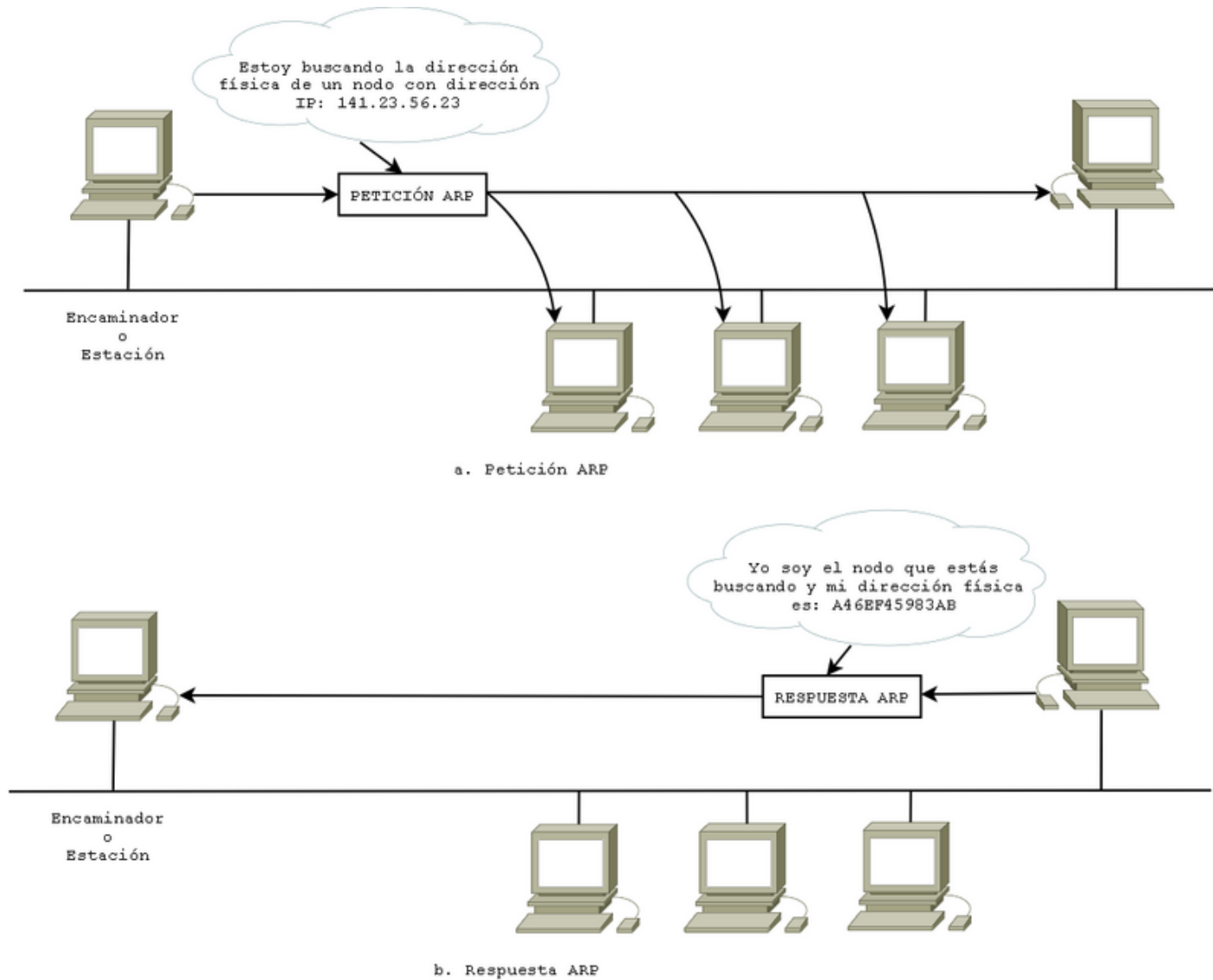


DNS Spoofing

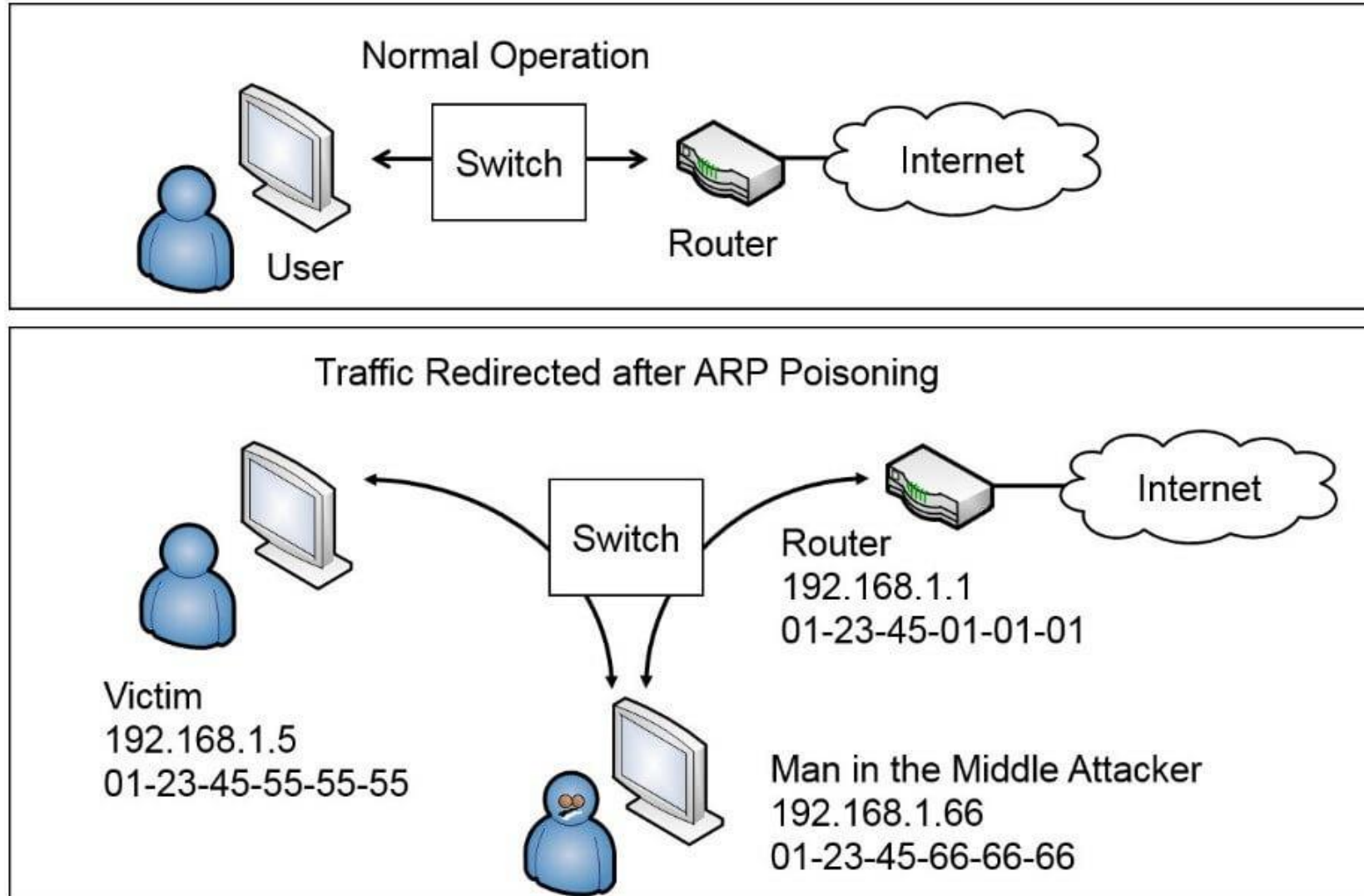
DNS Cache Poisoning



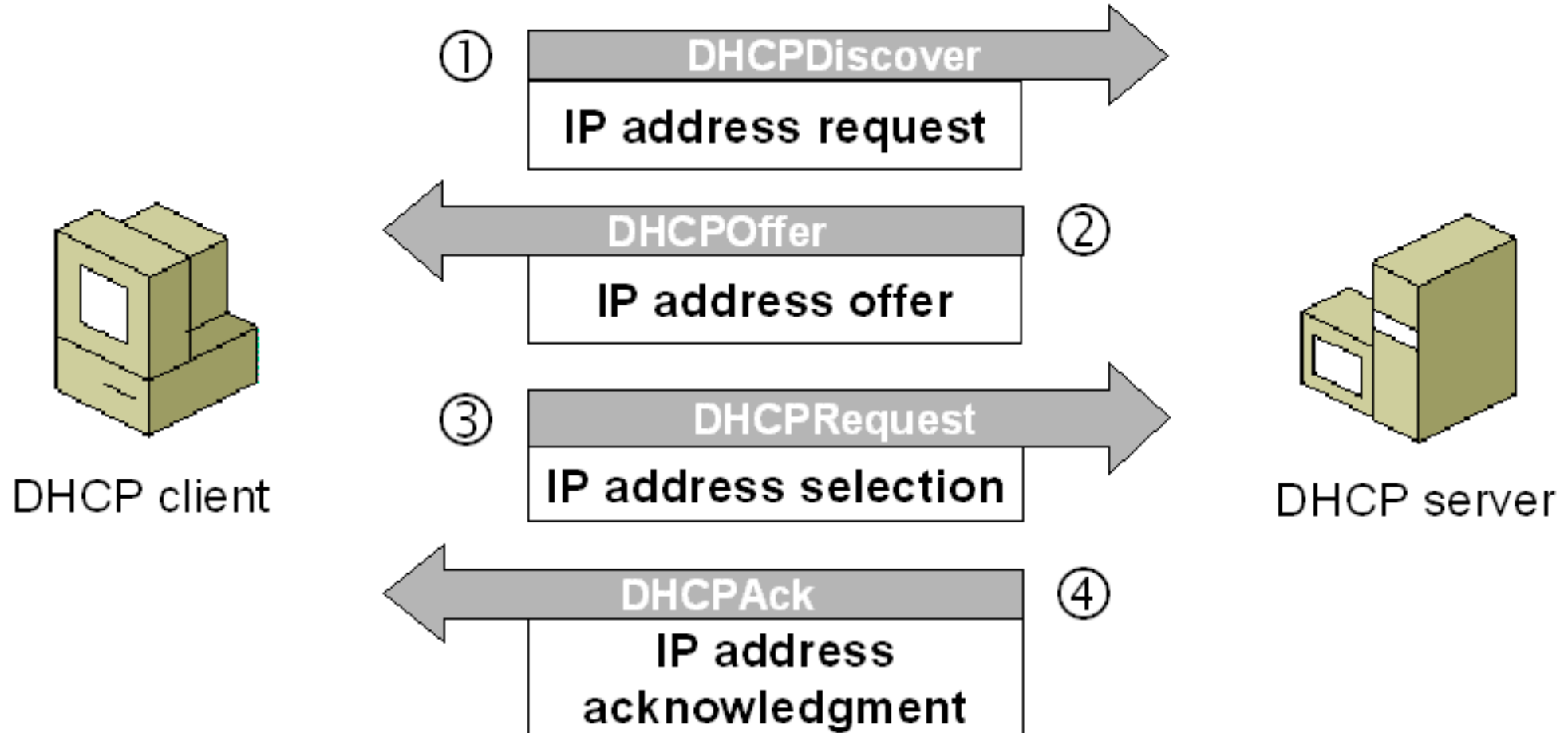
ARP Spoofing



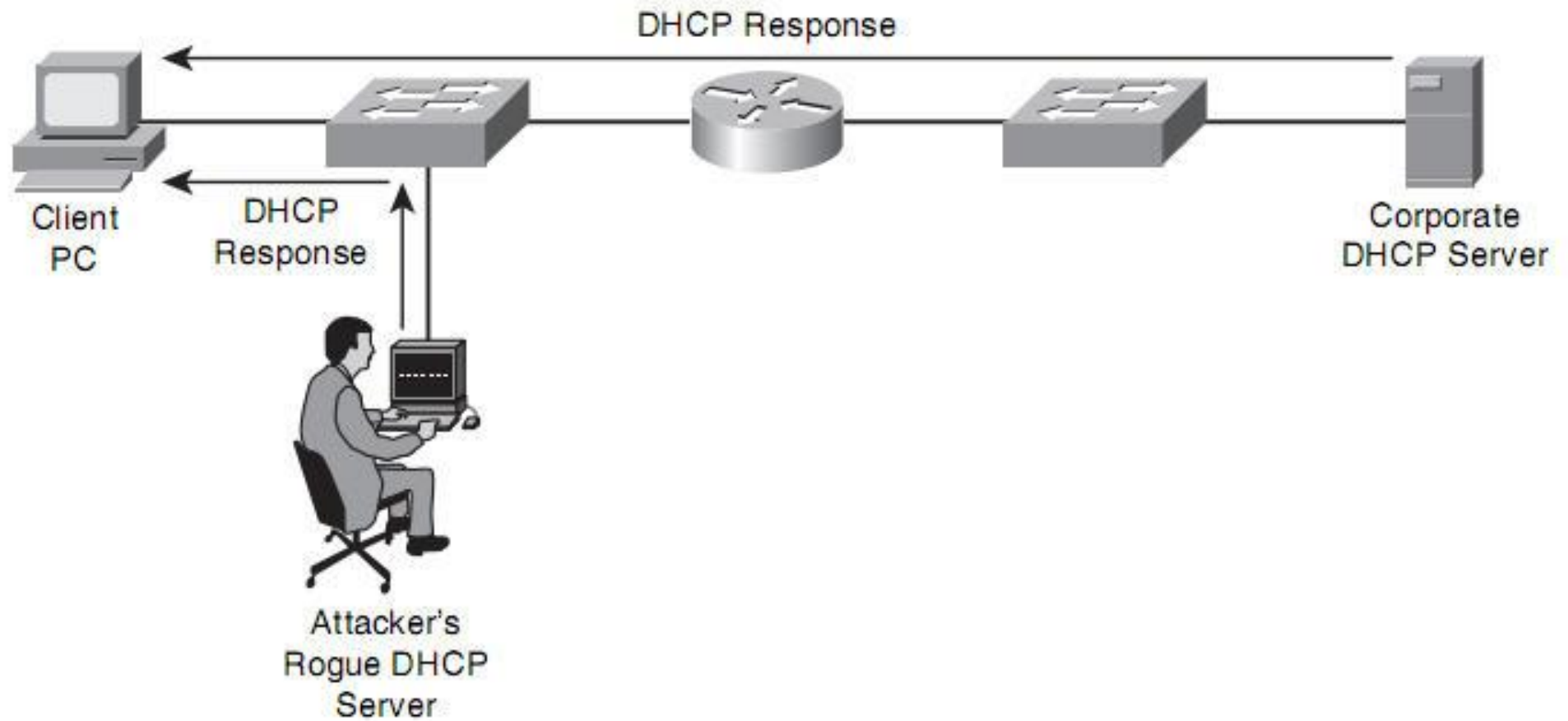
ARP Spoofing



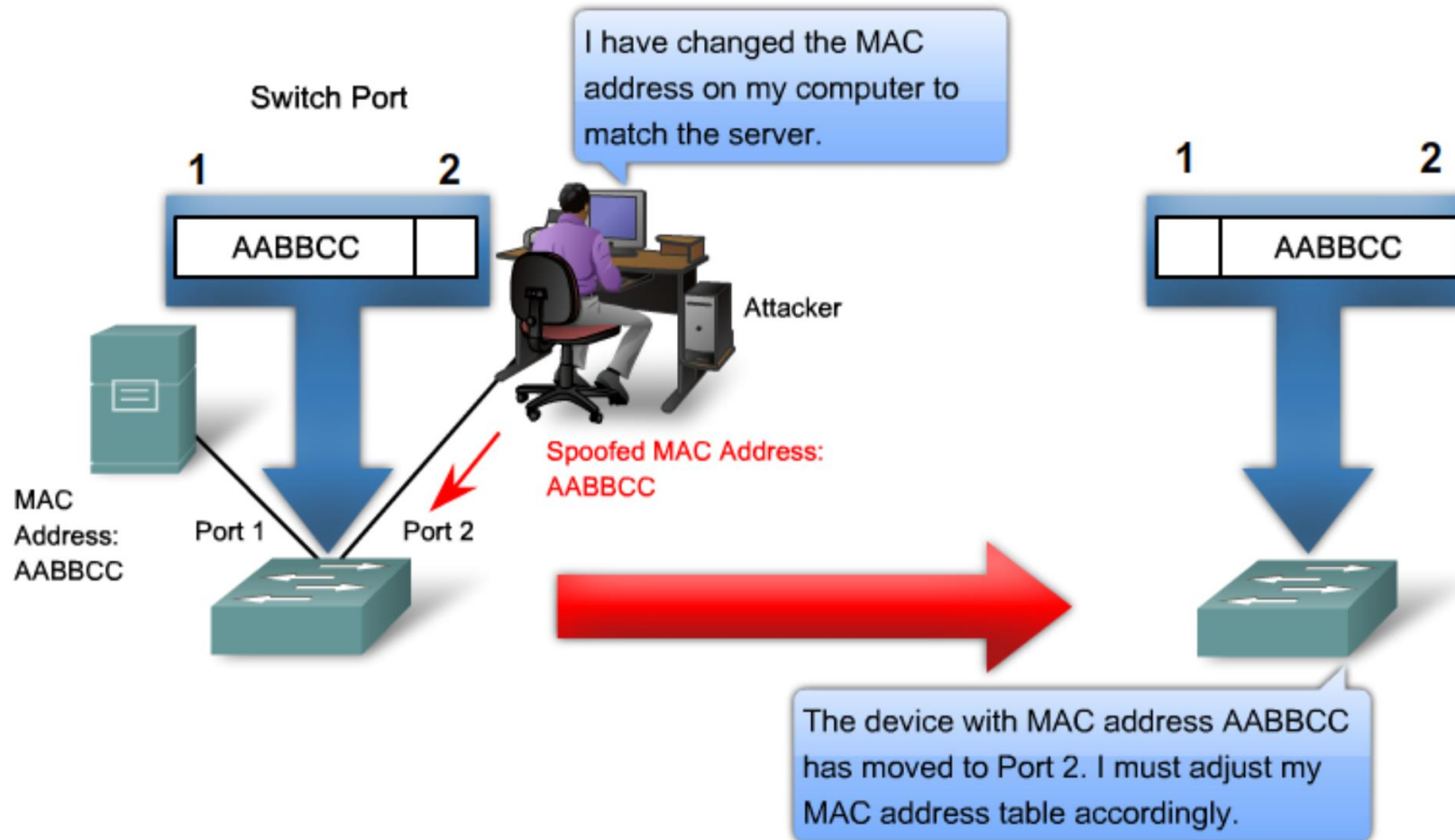
DHCP Protocol



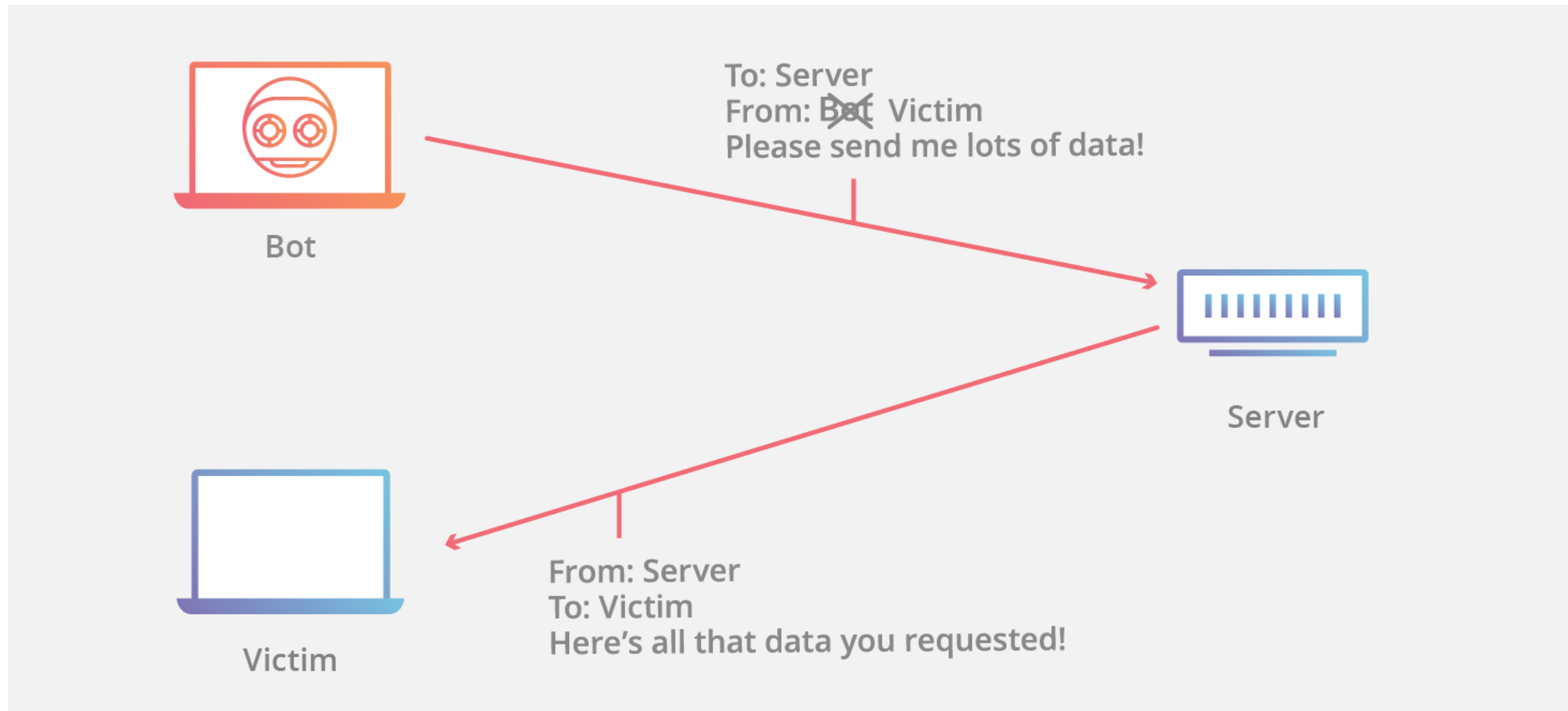
DHCP Spoofing



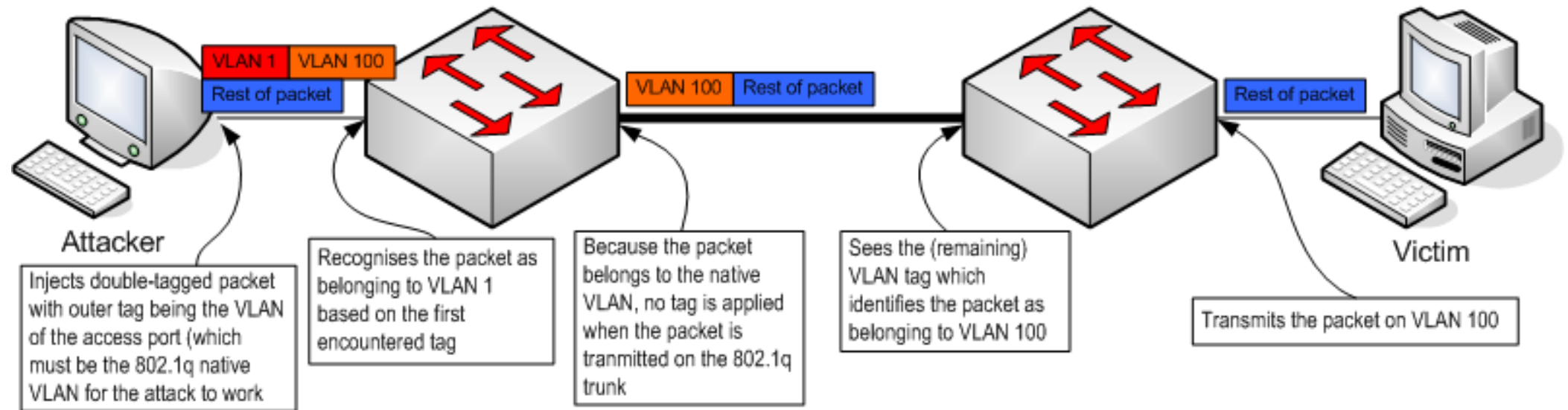
MAC Spoofing



IP Spoofing



VLAN Hopping

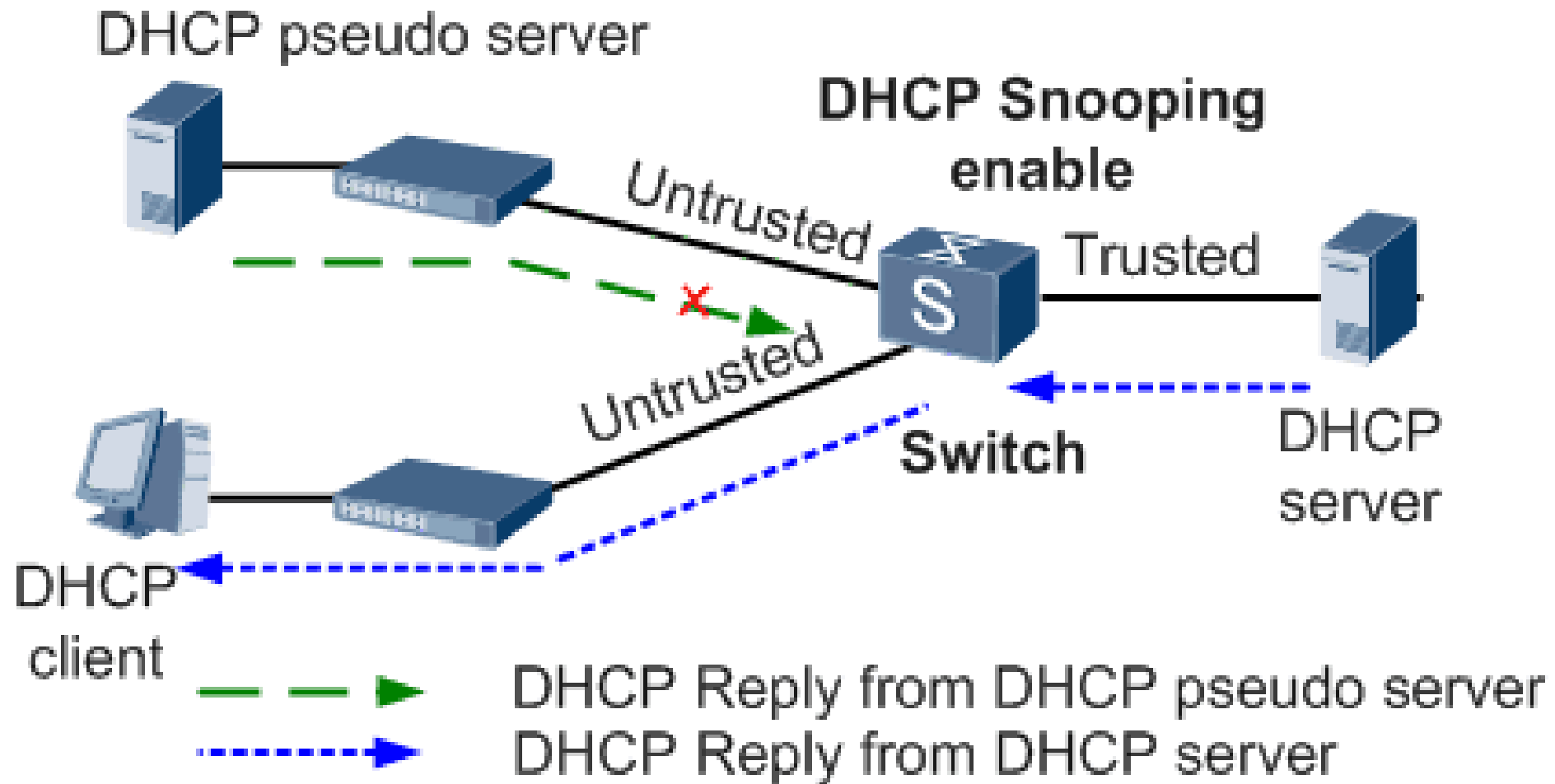


Port Security:

Example 1-1 *Comprehensive Port Security Configuration*

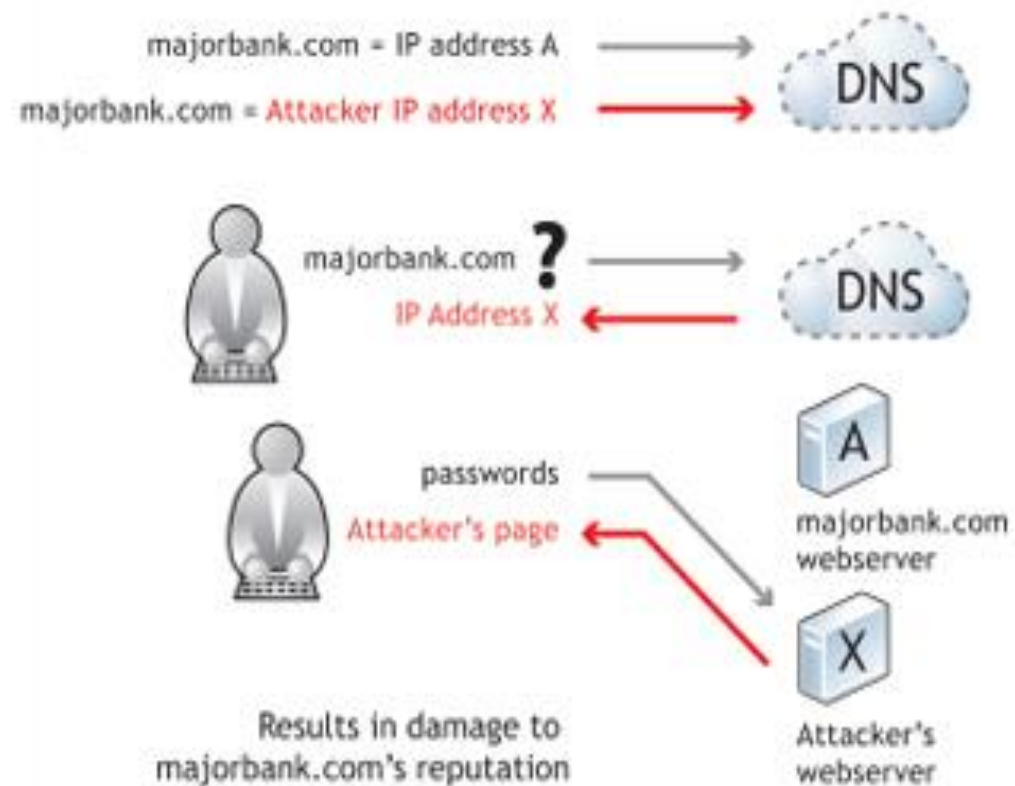
```
Cat3550(config)# interface gigabitethernet 0/5
Cat3550(config-if)# switchport mode access
Cat3550(config-if)# switchport port-security
Cat3550(config-if)# switchport port-security maximum 5
Cat3550(config-if)# switchport port-security violation protect
Cat3550(config-if)# switchport port-security mac-address 1234.1234.1234
Cat3550(config-if)# switchport port-security mac-address sticky
Cat3550(config-if)# end
```

DHCP Snooping

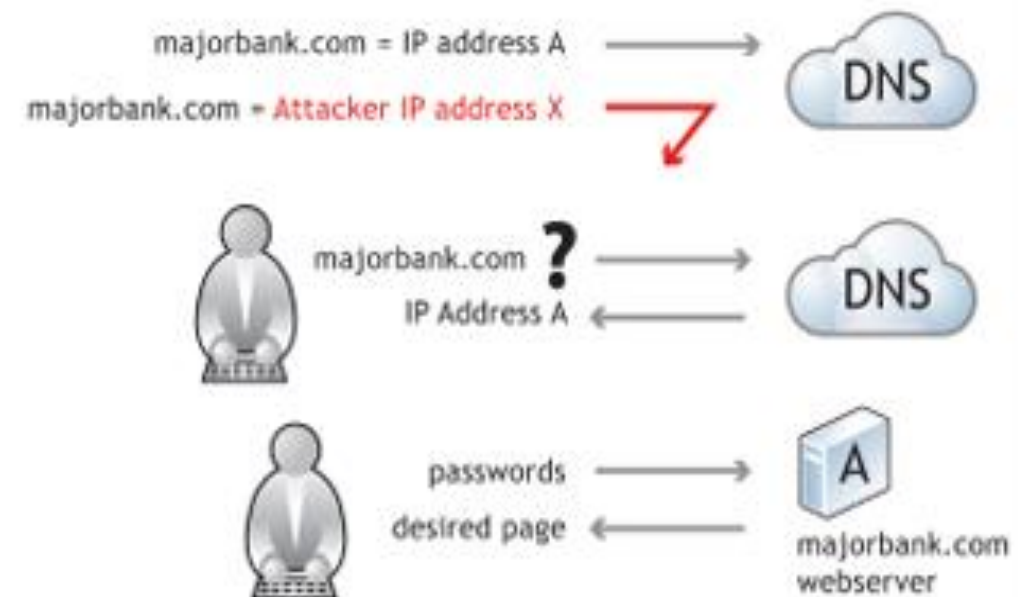


DNS Sec

Without DNSSEC



With DNSSEC



ARP Spoofing

ARP Watch

IP-address:

MAC-address:

Display period: all (0 seconds), IP = all, MAC = 2f:3a:56:30:ba:ad

Last hour only: [IP-based](#) [MAC-based](#) [Top stats](#)
 Last day only (default): [IP-based](#) [MAC-based](#) [Top stats](#)
 All: [IP-based](#) [MAC-based](#) [Top stats](#)

IP	What	IP	Old MAC	Time	Old time	Delta
2f:3a:56:30:ba:ad						
	new station	192.168.185.68		Wed Apr 9 08:55:56 2008		
	new station	192.168.185.68		Tue Jul 1 09:30:40 2008		
	changed ethernet address	192.168.185.7	2f:a3:a0:95:ba:7c	Mon Aug 4 16:33:23 2008	Mon Aug 4 16:25:42 2008	461 seconds
	changed ethernet address	192.168.185.74	2f:56:8:46:e2:3	Mon Aug 4 16:33:46 2008	Mon Jul 14 22:46:58 2008	1792008 seconds
	new station	192.168.185.191		Mon Aug 4 16:52:51 2008		
	changed ethernet address	192.168.185.188	2f:a2:b:9d:3c:78	Mon Aug 4 16:53:23 2008	Sun Aug 3 13:53:46 2008	97177 seconds
	flip flop	192.168.185.188	2f:a2:b:9d:3c:78	Wed Aug 6 22:06:09 2008	Wed Aug 6 22:04:00 2008	129 seconds
	flip flop	192.168.185.188	2f:a2:b:9d:3c:78	Wed Aug 6 22:06:35 2008	Wed Aug 6 22:06:14 2008	21 seconds
	flip flop	192.168.185.188	2f:a2:b:9d:3c:78	Thu Aug 7 12:11:35 2008	Thu Aug 7 10:57:37 2008	4438 seconds
	flip flop	192.168.185.188	2f:a2:b:9d:3c:78	Thu Aug 7 12:12:01 2008	Thu Aug 7 12:11:35 2008	26 seconds
	flip flop	192.168.185.188	2f:a2:b:9d:3c:78	Thu Aug 7 15:20:04 2008	Thu Aug 7 12:13:46 2008	11178 seconds
	changed ethernet address	192.168.185.99	2f:6d:fc:f7:4f:10	Fri Aug 8 14:49:13 2008	Fri Aug 8 12:55:05 2008	6848 seconds
	changed ethernet address (cs.homelink.ru)	192.168.184.99	2f:54:9f:3:2d:cb	Fri Aug 8 14:50:25 2008	Fri Aug 8 14:40:26 2008	599 seconds
	new station	192.168.185.232		Sat Aug 9 14:59:55 2008		
	changed ethernet address	192.168.185.25	2f:54:23:c6:9b:f5	Tue Aug 12 14:03:33 2008	Tue Aug 12 12:59:31 2008	3842 seconds
	new station	192.168.185.155		Tue Aug 12 14:12:07 2008		

Herramientas para Sniffing

- **Wireshark:**
- Es un analizador de protocolos utilizado para realizar análisis y solucionar problemas en redes de comunicaciones, para análisis de datos y protocolos, y como una herramienta didáctica. Cuenta con todas las características estándar de un analizador de protocolos.
- La funcionalidad que provee es similar a la de tcpdump, pero añade una interfaz gráfica y muchas opciones de organización y filtrado de información. Así, permite ver todo el tráfico que pasa a través de una red, estableciendo la configuración en modo promiscuo. También, incluye una versión basada en texto llamada Tshark.

Herramientas para sniffing

(Untitled) - Wireshark

File Edit View Go Capture Analyze Statistics Help

Filter: + Expression... Clear Apply

No. -	Time	Source	Destination	Protocol	Info
13	3.684027	AsustekC_16:09:67	Broadcast	ARP	Who has 10.8.0.23? Tell 10.8.1.20
14	4.005863	Giga-Byt_2a:6d:dd	Broadcast	ARP	Who has 10.8.0.2? Tell 10.8.1.122
15	4.006422	Giga-Byt_2a:6d:dd	Broadcast	ARP	Who has 10.8.1.234? Tell 10.8.1.122
16	4.021983	Cisco_0c:16:8b	Spanning-tree-(for-br	STP	Conf. Root = 32769/00:12:80:0c:16:80 Cost = 0 Port =
17	4.198393	10.8.1.111	10.8.1.255	NBNS	Name query NB 401_WOJCIK<00>
18	4.457166	Giga-Byt_26:fb:97	Broadcast	ARP	Who has 10.8.0.2? Tell 10.8.0.221
19	4.833274	00000001.00a0d2133ff	00000001.ffffffffffff	IPX RIF	Response
20	4.948417	10.8.1.111	10.8.1.255	NBNS	Name query NB 401_WOJCIK<00>
21	5.347255	10.8.0.90	10.8.0.2	DNS	Standard query AAAA www.onet.pl
22	5.347647	10.8.0.2	10.8.0.90	DNS	Standard query response
23	5.347694	10.8.0.90	10.8.0.2	DNS	Standard query AAAA www.onet.pl
24	5.347874	10.8.0.2	10.8.0.90	DNS	Standard query response
25	5.347905	10.8.0.90	10.8.0.2	DNS	Standard query A www.onet.pl
26	5.348216	10.8.0.2	10.8.0.90	DNS	Standard query response A 213.180.130.200
27	5.348319	10.8.0.90	213.180.130.200	TCP	34348 > www [SYN] Seq=0 Len=0 MSS=1460 TSV=1086275 TSEF
28	5.358254	213.180.130.200	10.8.0.90	TCP	www > 34348 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=
29	5.358297	10.8.0.90	213.180.130.200	TCP	34348 > www [ACK] Seq=1 Ack=1 Win=5840 Len=0 TSV=10862

Frame 18 (60 bytes on wire, 60 bytes captured)

Ethernet II, Src: Giga-Byt_26:fb:97 (00:0d:61:26:fb:97), Dst: Broadcast (ff:ff:ff:ff:ff:ff)

Address Resolution Protocol (request)

Hardware type: Ethernet (0x0001)

Protocol type: IP (0x0800)

Hardware size: 6

Protocol size: 4

Encapsulated: request (0x0001)

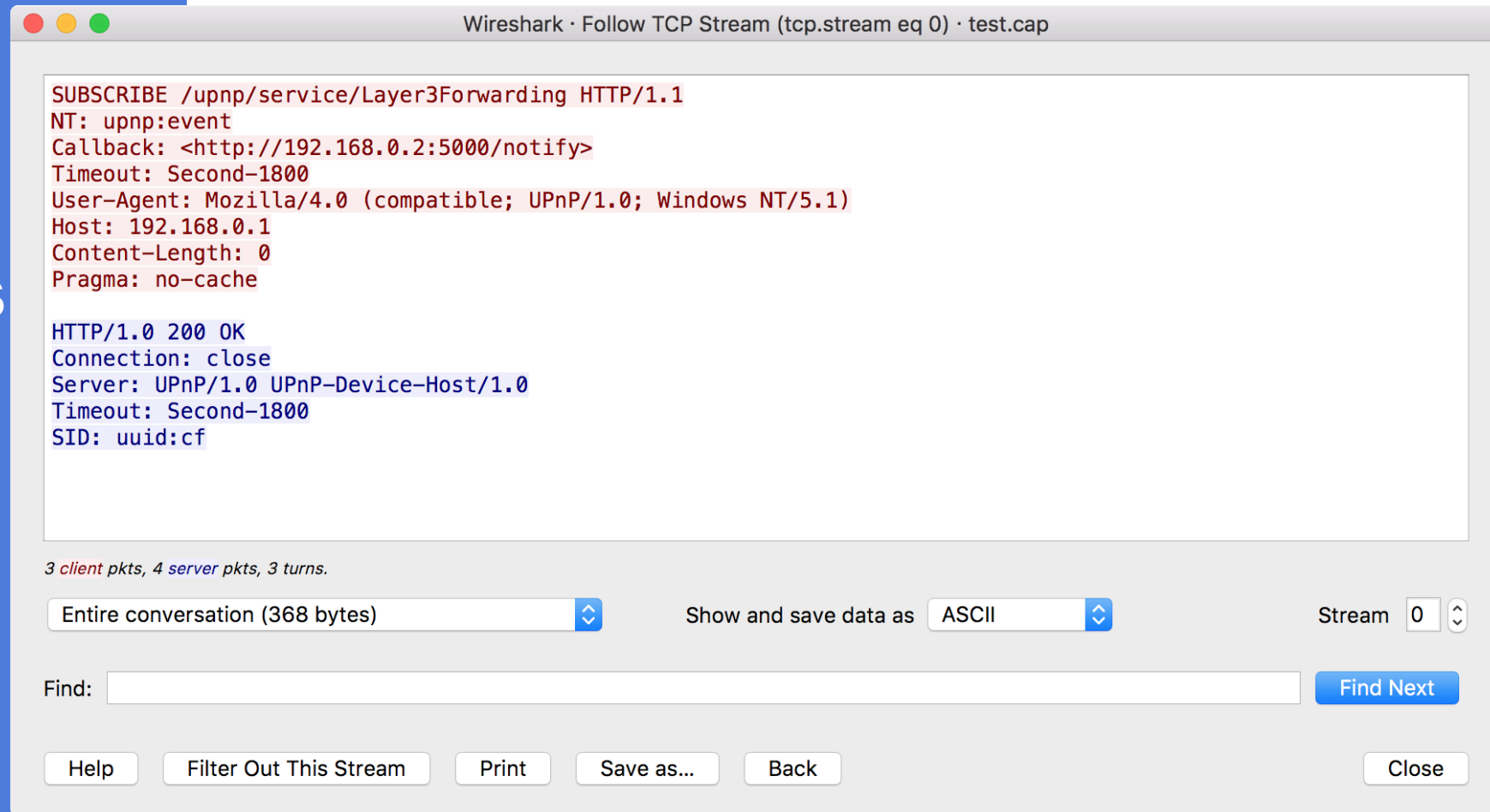
```

0000  ff ff ff ff ff ff 00 0d 61 26 fb 97 08 06 00 01 ..... a&.....
0010  08 00 06 04 00 01 00 0d 61 26 fb 97 0a 08 00 dd ..... a&.....
0020  00 00 00 00 00 00 0a 08 00 02 20 20 20 20 20 20 ..... 
0030  20 20 20 20 20 20 20 20 20 20 20 20 20 20 20 20
  
```

Address Resolution Protocol (arp), 28 bytes

P: 173 D: 173 M: 0 Drops: 0

Herramientas para sniffing



Filtros con Wireshark

ip.addr == 192.168.1.40	Visualizar tráfico por host 192.168.1.40
ip.addr != 192.168.1.25	Visualizar todo el tráfico excepto host 192.168.1.25
ip.dst == 192.168.1.30	Visualizar por host destino 192.168.1.30
ip.src == 192.168.1.30	Visualizar por host origen 192.168.1.30
ip	Visualiza todo el tráfico IP
tcp.port == 143	Visualiza todo el tráfico origen y destino puerto 143
ip.addr == 192.168.1.30 and tcp.port == 143	Visualiza todo el tráfico origen y destino puerto 143 relativo al host 192.168.1.30
http contains <i>"http://www.terra.com"</i>	Visualiza el tráfico origen y destino http://www.terra.com . Visualiza los paquetes que contienen http://www.terra.com en el contenido en protocolo http.
frame contains <i>"@miempresa.es"</i>	Visualizamos todos los correos con origen y destino al dominio miempresa.es , incluyendo usuarios , pass , etc

A black and white photograph of a woman in a server room. She is standing in a narrow aisle between rows of server racks. She is holding a tablet in her left hand and pointing with her right index finger at a label on one of the server racks. The room is dimly lit, with bright rectangular lights on the ceiling. The server racks are filled with various electronic components and cables.

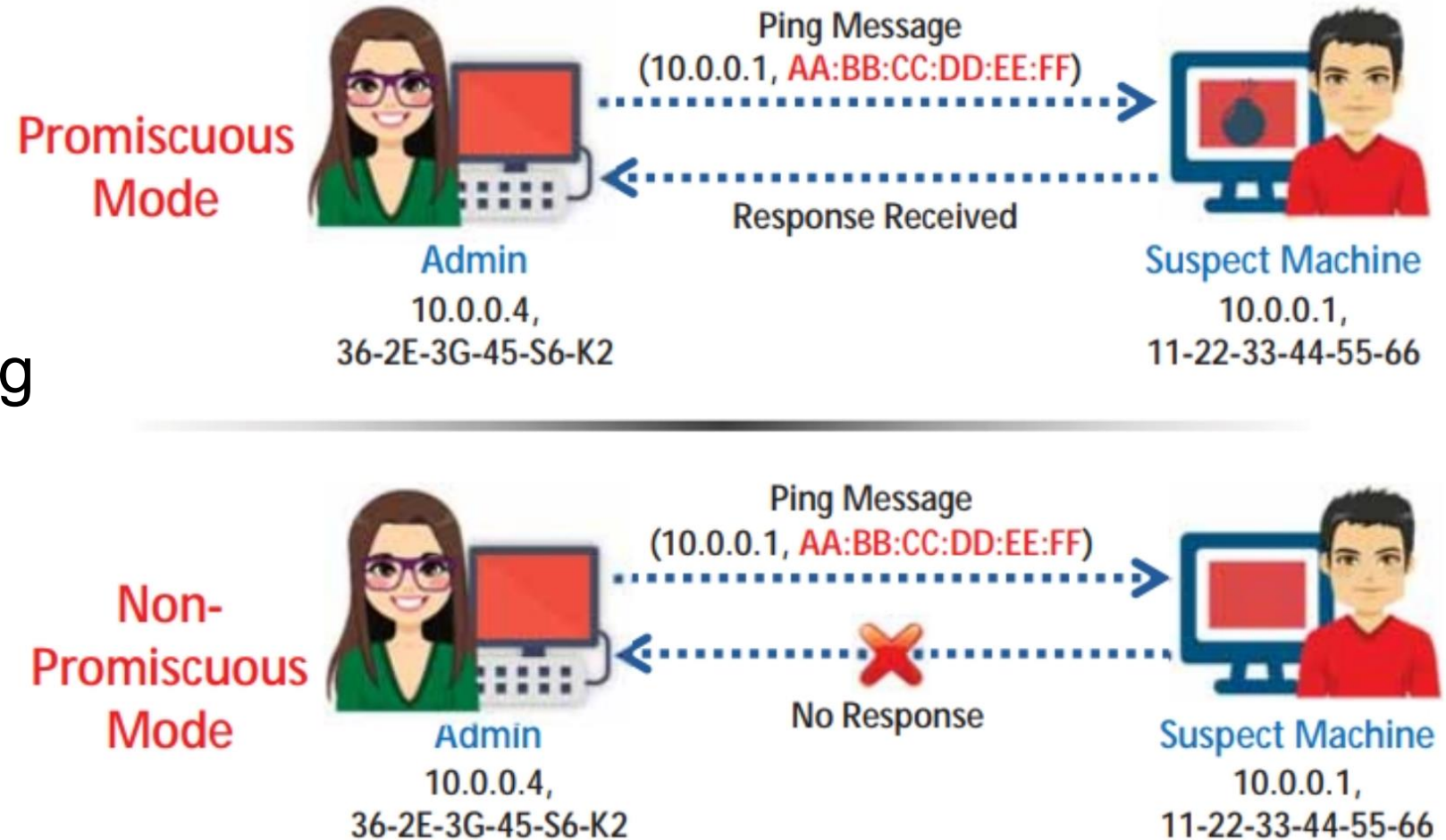
03

Técnicas de detección de sniffing

Técnicas de detección

- Método del ping

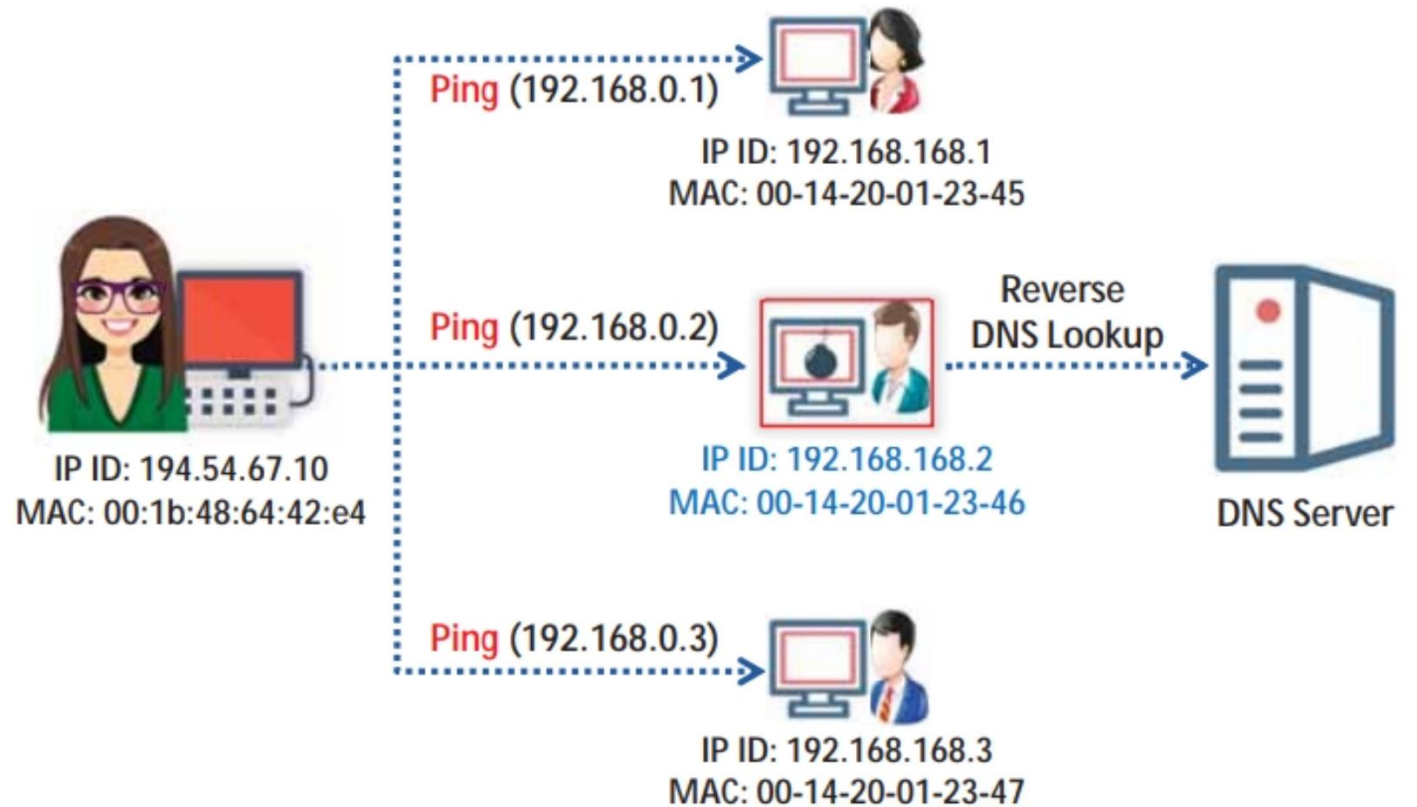
Se envía un ping con la MAC adulterada.



Técnicas de detección

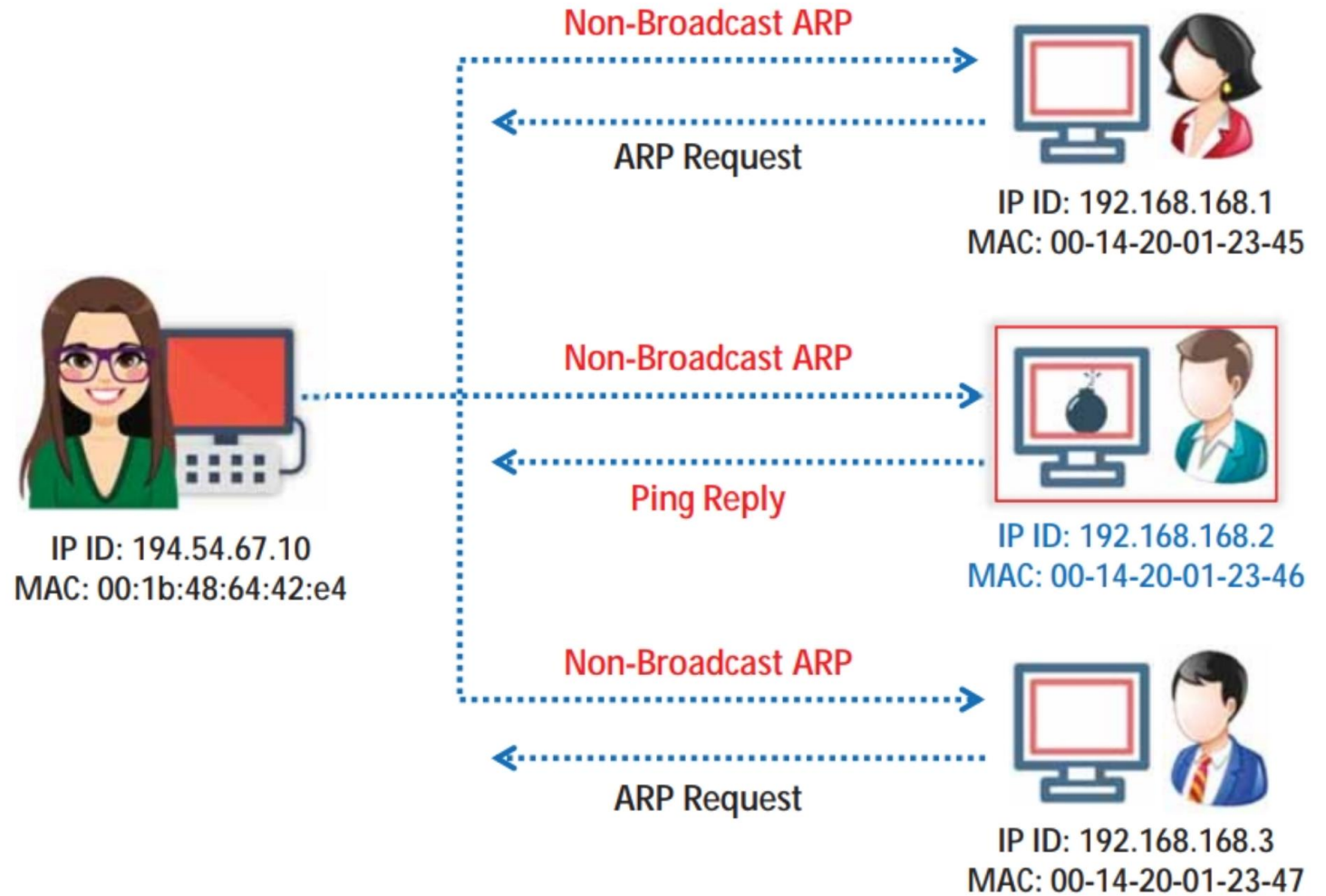
- Método del DNS

- Most of the sniffers perform **reverse DNS lookups** to identify the machine from the IP address



- Método de ARP

Técnicas de detección



Técnicas de detección

- Usando NMAP

```
# nmap --script sniffer-detect.nse 10.0.2.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-29 10:44 EDT
Nmap scan report for 10.0.2.1
Host is up (0.00052s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Host script results:
|_sniffer-detect: Likely in promiscuous mode (tests: "11111111")

Nmap scan report for 10.0.2.2
Host is up (0.0011s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
445/tcp   open  microsoft-ds
902/tcp   open  iss-realsecure
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Host script results:
|_sniffer-detect: Likely in promiscuous mode (tests: "11111111")
```

Recomendaciones

- Restringir el acceso físico a la red (NAC).
- Utilizar cifrado en las comunicaciones confidenciales.
- Utilizar herramientas de detección de ARP Spoofing.
- Segmentar la red.
- Utilizar protocolos seguros como SSH, HTTPS, SCP, etc.
- Utilizar switches en lugar de hubs.
- Utilizar mecanismos de autenticación robusta.



04

Conclusiones

Conclusiones

- Las redes internas suelen usar protocolos antiguos y vulnerables que facilitan la explotación de datos sensibles por parte de atacantes.
- El monitoreo y captura de tráfico (sniffing), tanto pasivo como activo, es una técnica crítica que puede comprometer información confidencial si no se toman medidas adecuadas.
- Técnicas como **MAC Flooding**, **ARP Spoofing** y **DNS Poisoning** explotan vulnerabilidades en la red, destacando la importancia de implementar contramedidas.
- Medidas como el uso de protocolos seguros (SSH, HTTPS), segmentación de red y herramientas como Wireshark son esenciales para detectar y mitigar ataques basados en sniffing.

DuocUC[®]

CERCANÍA. LIDERAZGO. FUTURO.

(duoc.cl)

7 AÑOS
ACREDITADO



DESDE AGOSTO 2017 HASTA AGOSTO 2024.
DOCENCIA DE PREGRADO. GESTIÓN
INSTITUCIONAL. VINCULACIÓN CON EL MEDIO.